UNIVERSITY OF SOUTH CAROLINA

ITEC 493: IT Security for Managers

Application and Networking-based Attacks

Ali Mazloum
Integrated Information Technology Department
College of Engineering and Computing
University of South Carolina

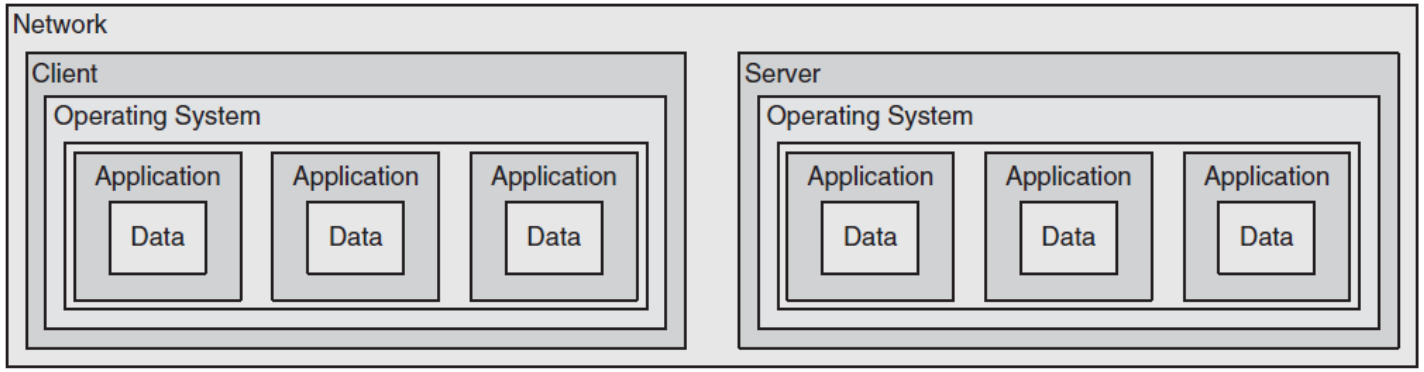
Fall 2025

Objectives

- List and explain the different types of server-side web application attacks
- Define client-side attacks
- Explain how overflow attacks works
- List different types of networking-based attacks

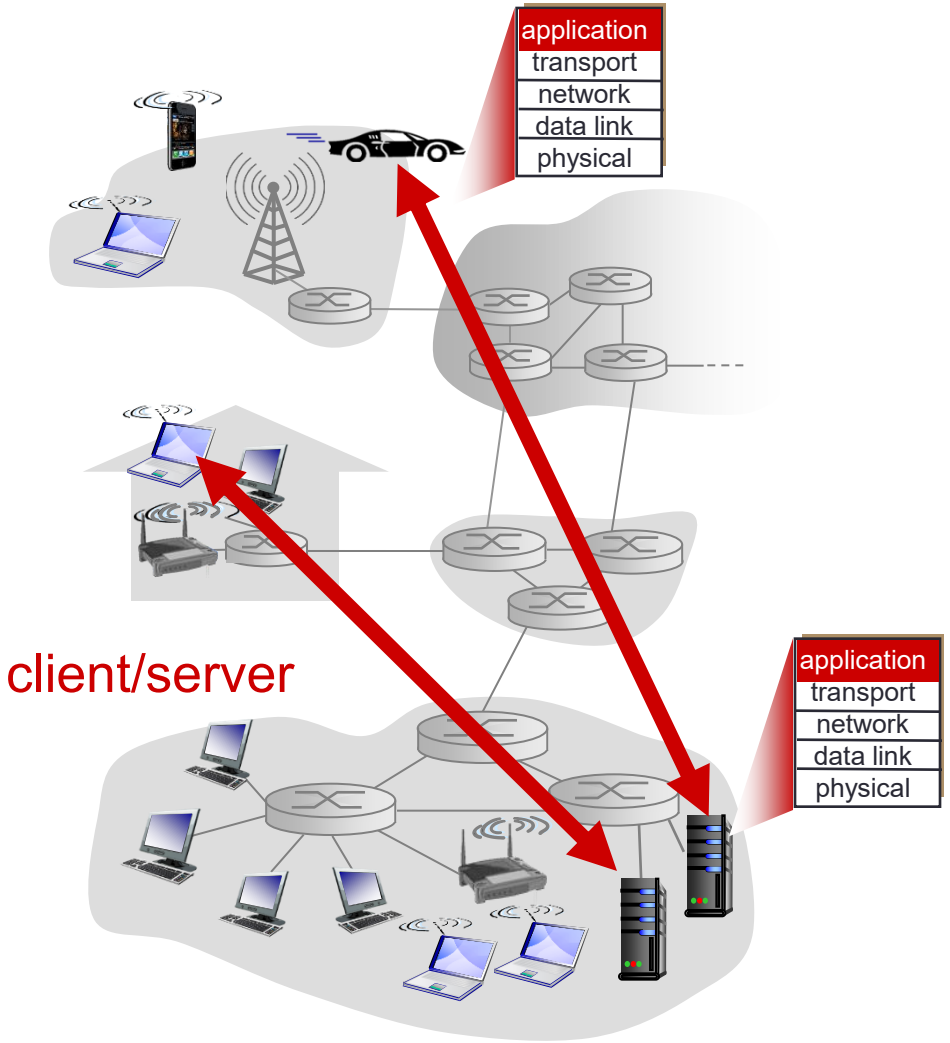
Conceptual Networked System

- Network used to connect clients and servers together
- Clients and servers run an operating system
- Operating system controls applications
- Applications manipulate data
- Attacks on the applications in a networked computer system can be directed toward the server, the client, or both



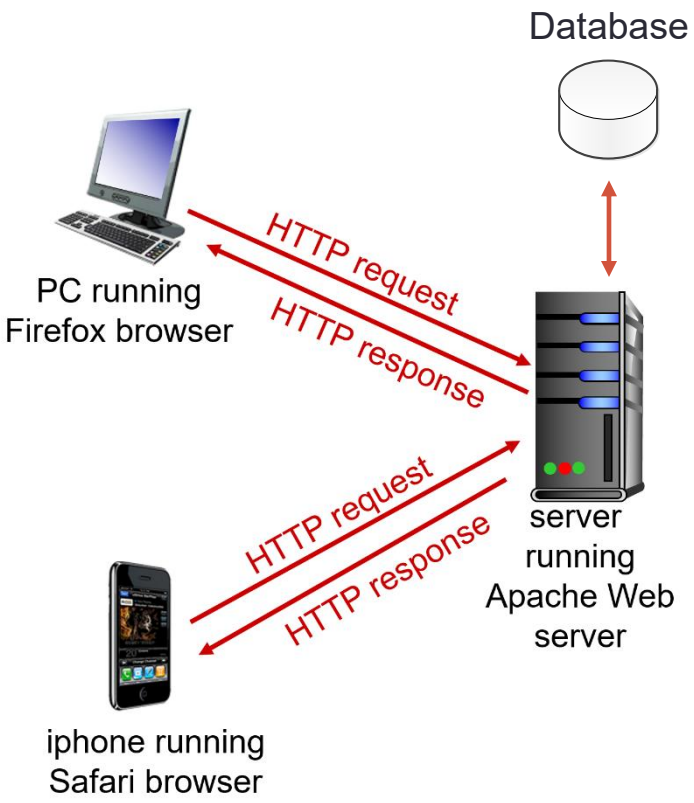
Server-Side Web Application Attacks

- Content provided to users who are "surfing the Web" is generated by a software application running on a server
- In providing web services to clients, web servers also *expose* those same services to attackers
- Web servers create dynamic content based on user's inputs



Server-Side Web Application Attacks

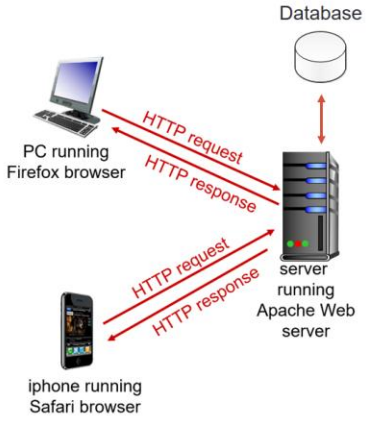
- Client's web browser makes a request using the Hypertext Transport Protocol (HTTP) to a web server
- Servers run the specific "web apps," which in turn are directly connected to databases on internal network
- Information from databases retrieved and returned to web server so dynamic information can be sent back to the user's web browser



HTTP Primer

- HTTP: hypertext transfer protocol
- Application layer protocol
- Client/server model
  - client: browser that requests, receives, (using HTTP protocol) and “displays” Web objects
  - server: web server sends (using HTTP protocol) objects in response to requests
- Some methods are safe, e.g., HEAD, GET, OPTIONS and TRACE
  - Intended only for information retrieval,

  no change in server state (“harmless”)



HTTP Message

- Two types of HTTP messages: *request*, *response*
- HTTP request message:
  - ASCII (human-readable format)

carriage return character

line-feed character

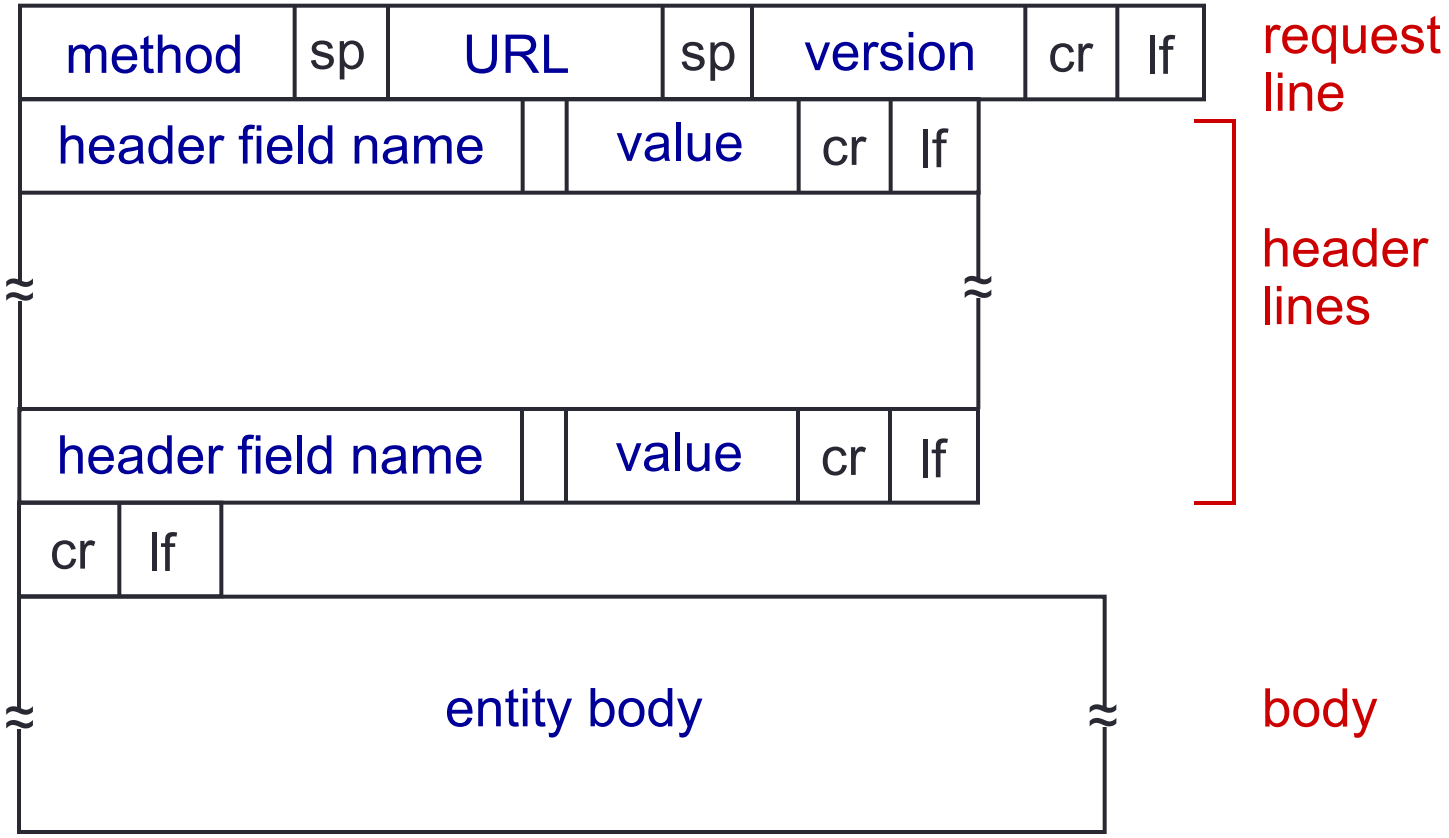
request line (GET, POST, HEAD commands)

header lines

carriage return, line feed at start of line indicates end of header lines

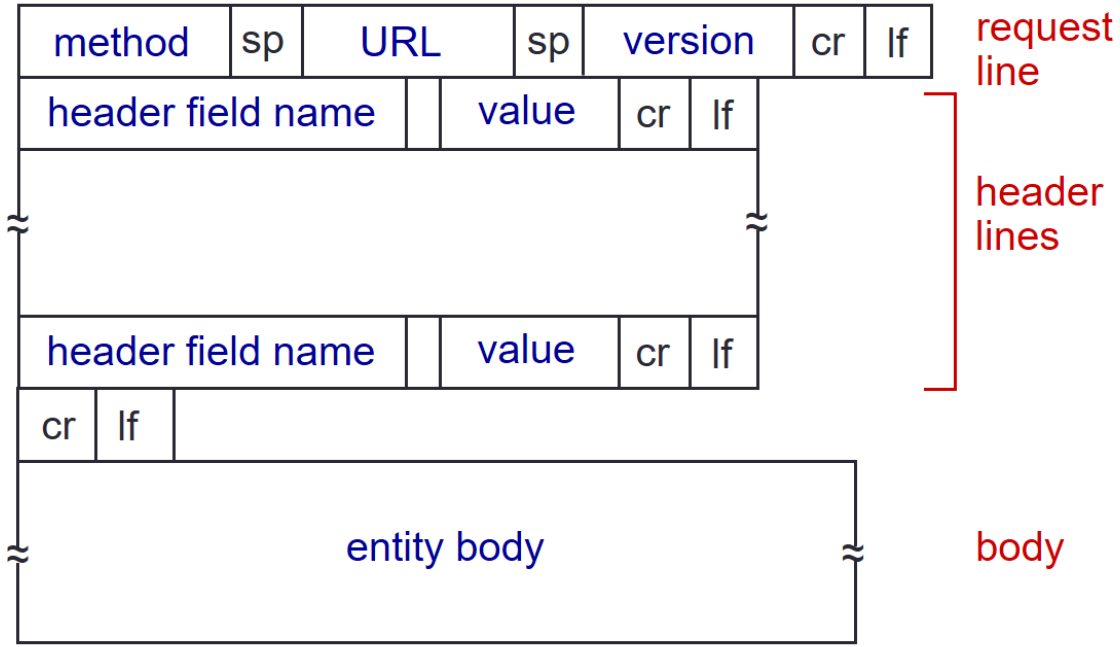
```
GET /index.html HTTP/1.1\r\n
Host: www-net.cs.umass.edu\r\n
User-Agent: Firefox/3.6.10\r\n
Accept: text/html,application/xhtml+xml\r\n
Accept-Language: en-us,en;q=0.5\r\n
Accept-Encoding: gzip,deflate\r\n
Accept-Charset: ISO-8859-1,utf-8;q=0.7\r\n
Keep-Alive: 115\r\n
Connection: keep-alive\r\n
\r\n
```

HTTP Request



HTTP Methods

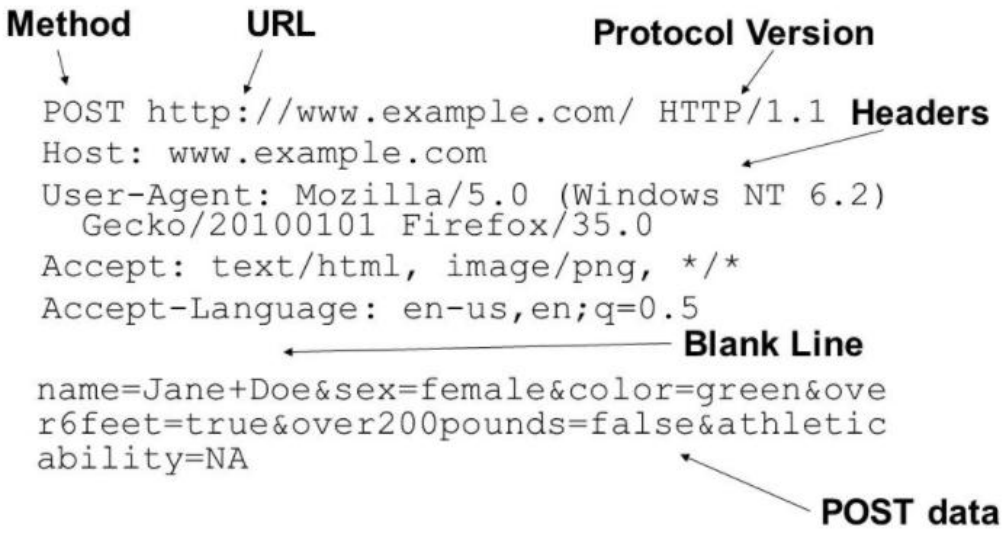
- GET - Requests a resource; it should only retrieve data
- HEAD - Asks for the response identical to the one that would correspond to a GET request, but without the response body; i.e., only metadata



HTTP Methods

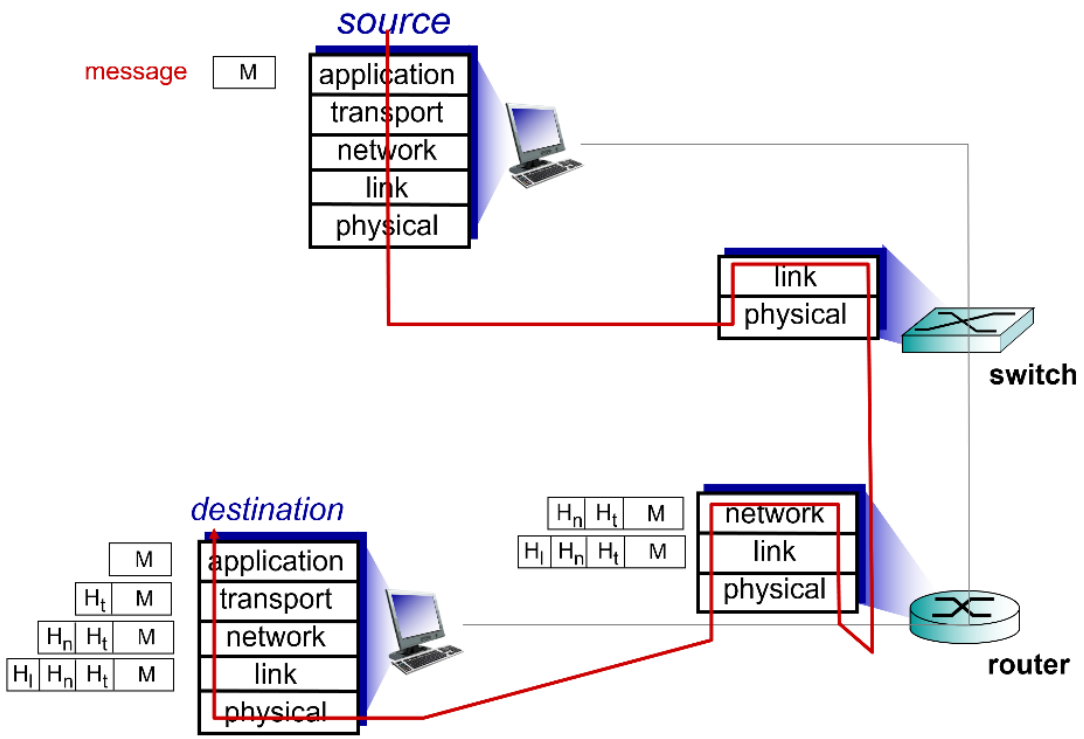
- POST - Requests that the server accept the entity. Data POSTed could be a message for a bulletin board, newsgroup, mailing list, or comment thread, or an item to add to a database
- PUT - Requests that the enclosed entity be stored
- DELETE - Deletes the specified resource
- PATCH - Applies partial modifications to a resource

HTTP POST Request



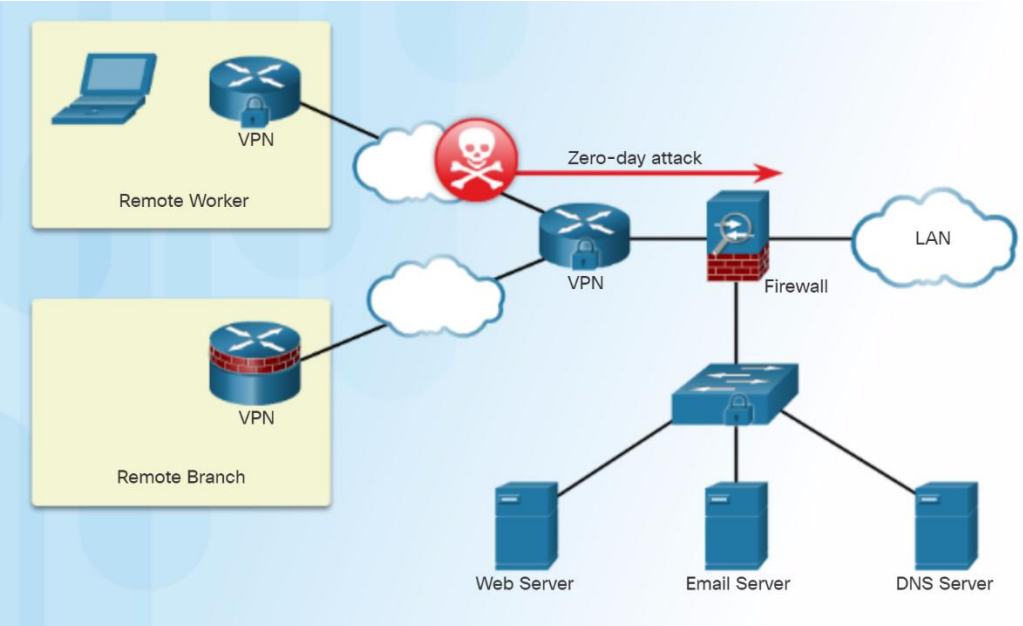
Securing Web Applications

- Traditional network security devices cannot always block web application attacks
  - Many traditional network security devices ignore the content of HTTP traffic
  - Switches: L2
  - Routers: L3
  - IPS: L2-L5 (to some extent)
  - Encrypted data…



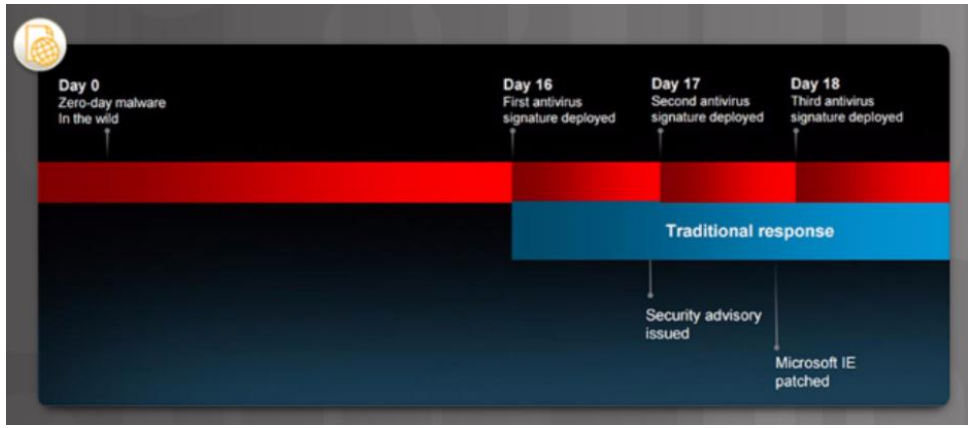
Zero Day Attacks

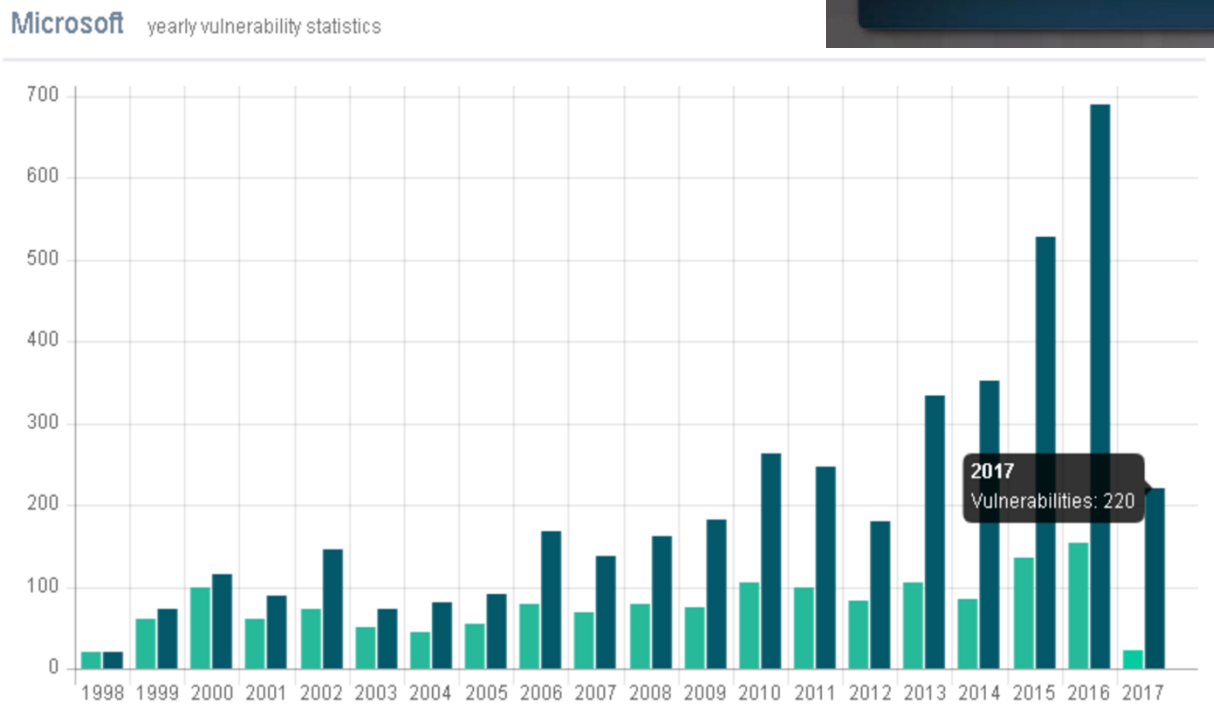
- Computer attack that exploits previously unknown vulnerabilities
- During the time it takes the software vendor to release a patch, the network is vulnerable



Zero Day Attacks

- Microsoft vulnerabilities





www.peerlyst.com/posts/microsoft-patched-another-zero-day-this-time-in-internet-explorer-valery-marchuk

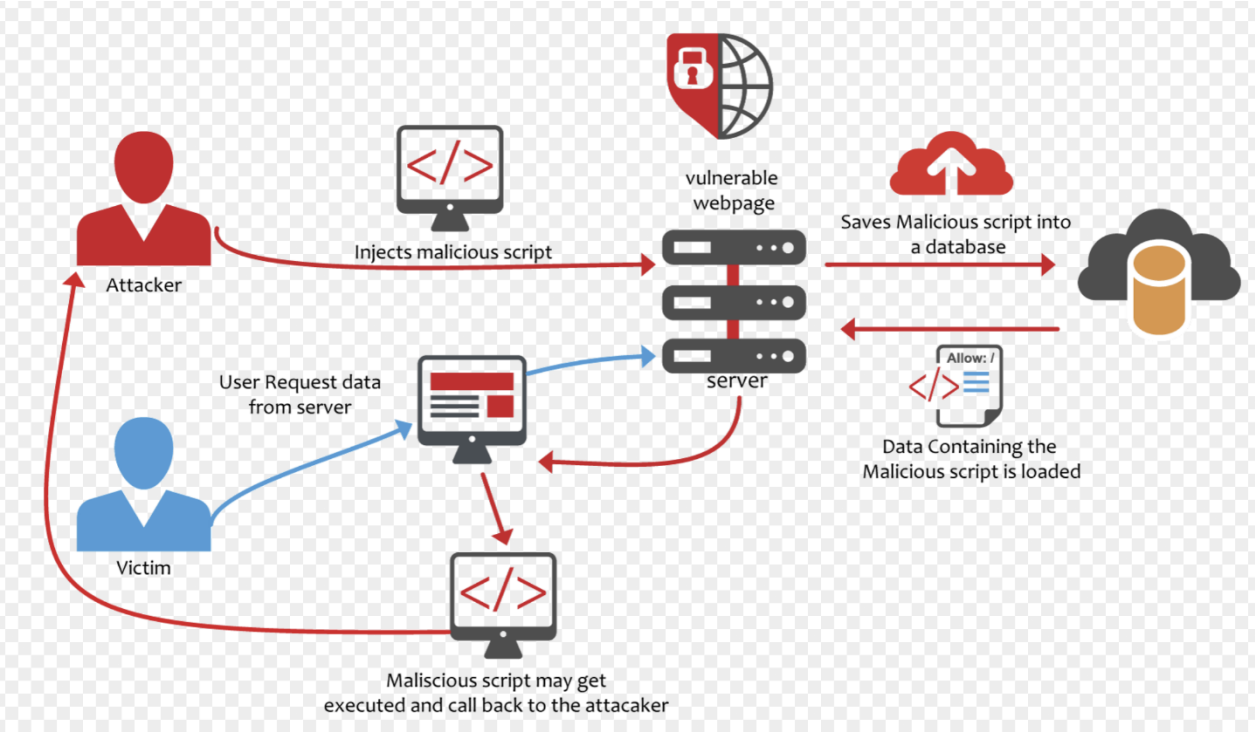
Common Application Attacks

- Server-side web application attacks target the input that the applications accept from users
  - Cross-site scripting
  - SQL injection
  - XML injection
  - Command injection/directory traversal

Cross-Site Scripting Platform

- Attackers use web server as platform to launch attacks on other computers
- XSS injects scripts into web server, and server:

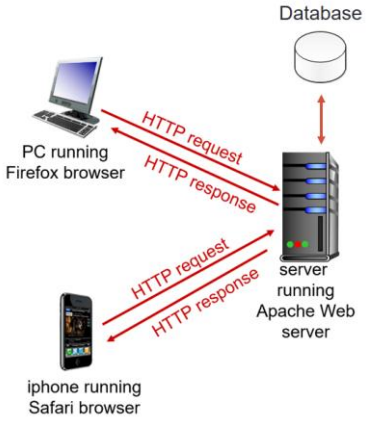
  (1) accepts user input without validating it; (2) Uses input in a response



SQL Injection

- Placement of malicious code in SQL statements, via web input
- Server accepts user input without validating (invalid input is processed and sent to the database)
- If attacker knows that anything he/she enters is processed unfiltered, then he/she can inject malicious code
- A crafted SQL statement input can extract information or manipulate database
- https://www.w3schools.com/sql/sql_injection.asp

SQL injection statement	Result
whatever' AND email IS NULL; --	Determine the names of different fields in the database
whatever' AND 1=(SELECT COUNT(*) FROM tabname); --	Discover the name of the table
whatever' OR full_name LIKE '%Mia%'	Find specific users
whatever'; DROP TABLE members; --	Erase the database table
whatever'; UPDATE members SET email = 'attacker-email@evil.net' WHERE email = 'Mia@good.com';	Mail password to attacker's email account



XML (Extensible Markup Language)

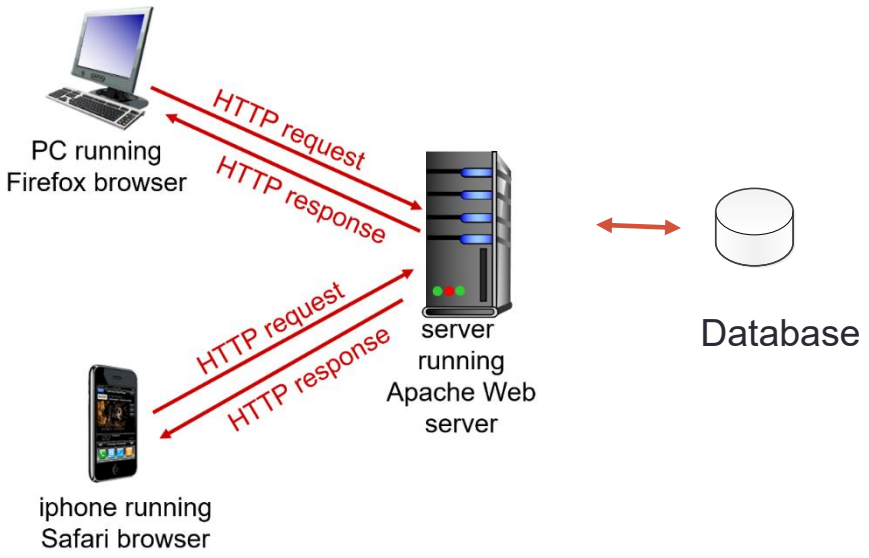
- Markup language is a method to add annotations to text
- Example is HTML:
  - Uses tags surrounded by brackets
  - Instructs browser to display text in specific format
- XML:
  - Carries data instead of indicating how to display it
  - No predefined set of tags
  - Users define their own tags

XML Attack

- Similar to SQL injection attack
- Attacker discovers Web site that does not filter user data
- Injects XML tags and data into the database

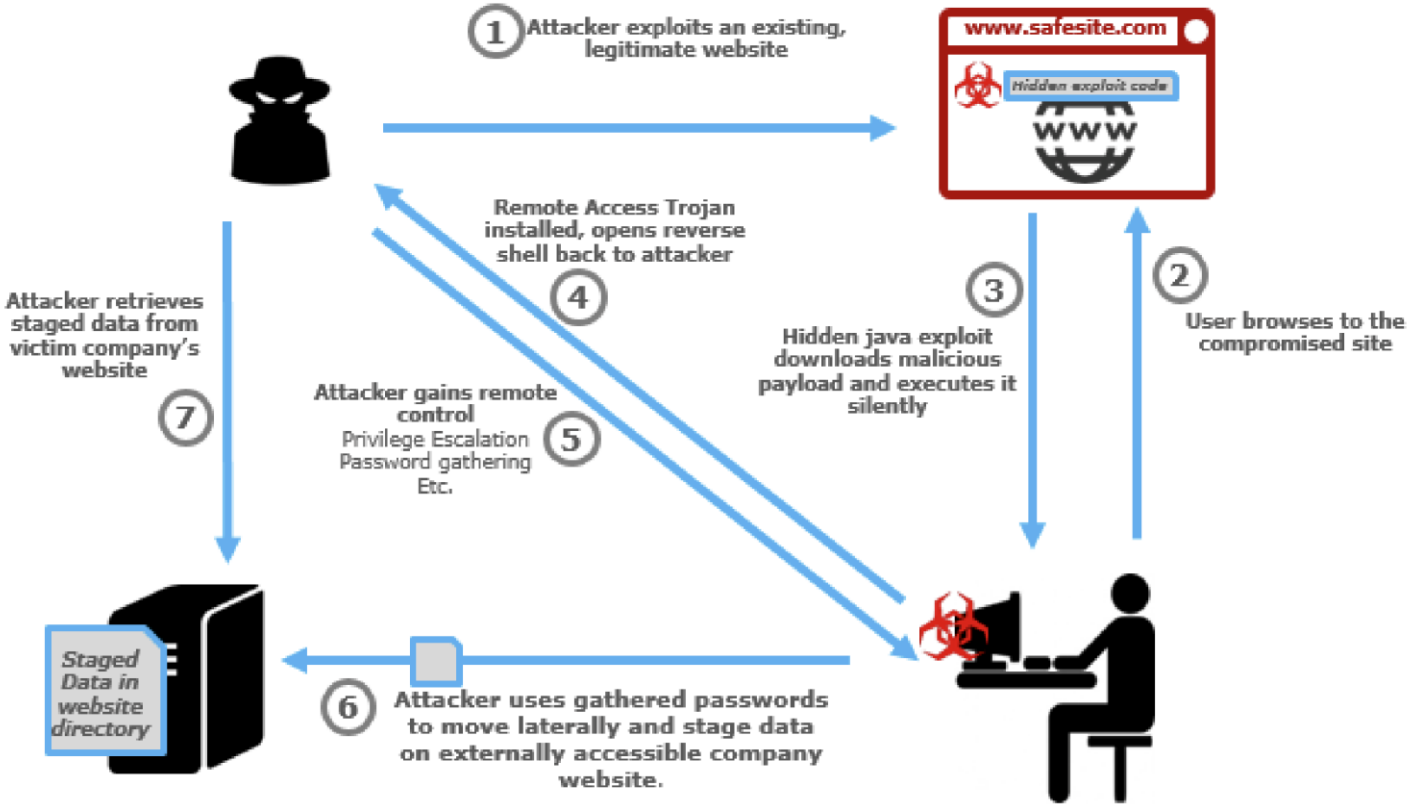
Client-Side Application Attacks

- Web application attacks are server-side attacks
- Client-side attacks target vulnerabilities in client applications:
  - Interacting with a compromised server
  - Client initiates connection with server, which could result in an attack



Drive-By Download

- *Drive-by download:* Client computer compromised simply by viewing a Web page



HTTP Header Manipulation

- HTTP header consists of fields containing information about the characteristics of data being transmitted
- The header fields are comprised of a field name, a colon, and the field value, such as Content-length: 49
- Attack modifies HTTP headers
- HTTP header manipulation allows attacker to pass malicious instructions to web browser via HTTP headers

HTTP field name	Source	Explanation	Example
Server	Web server	Type of web server	*Server: Apache*
Referer or Referrer	Web browser	The address of the previous webpage from which a link to the currently requested page was followed	*Referer: http://www.askapache .com/show-error-502/*
Accept-Language	Web browser	Lists of acceptable languages for content	*Accept-Language:en-us,en;q=0.5*
Set-Cookie	Web server	Parameters for setting a cookie on the local computer	*Set-Cookie: UserID=ThomasTrain; Max-Age=3600; Version=1*

HTTP Header Manipulation

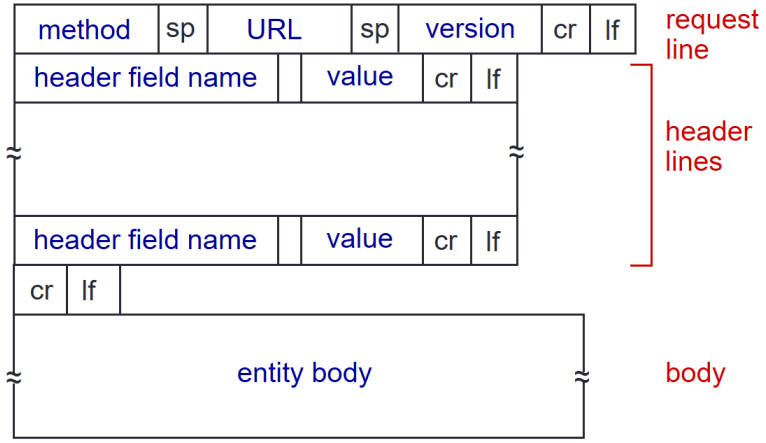
- Example of HTTP header

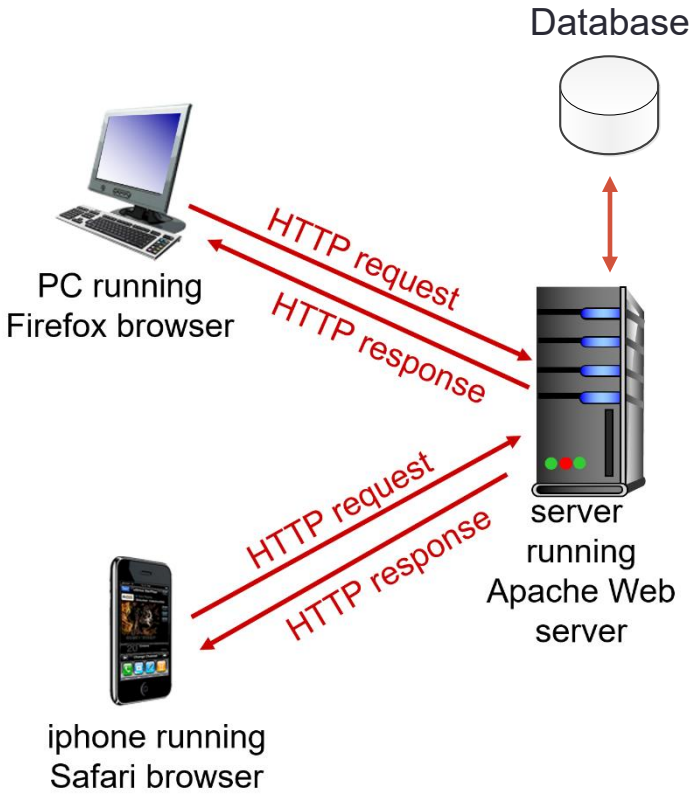
```
Internet Protocol Version 4, Src: 10.34.208.127, Dst: 151.101.129.67
Transmission Control Protocol, Src Port: 8947, Dst Port: 80, Seq: 1, Ack: 1, Len: 736
Hypertext Transfer Protocol
  > GET / HTTP/1.1\r\n
    Host: cnn.com\r\n
    Connection: keep-alive\r\n
    User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/63.0.3239.132 Safari/537.36\r\n
    Upgrade-Insecure-Requests: 1\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8\r\n
    Accept-Encoding: gzip, deflate\r\n
    Accept-Language: en-US,en;q=0.9\r\n
```

- HTTP header manipulation allows attacker to pass malicious instructions to web browser via HTTP headers

HTTP Header Manipulation

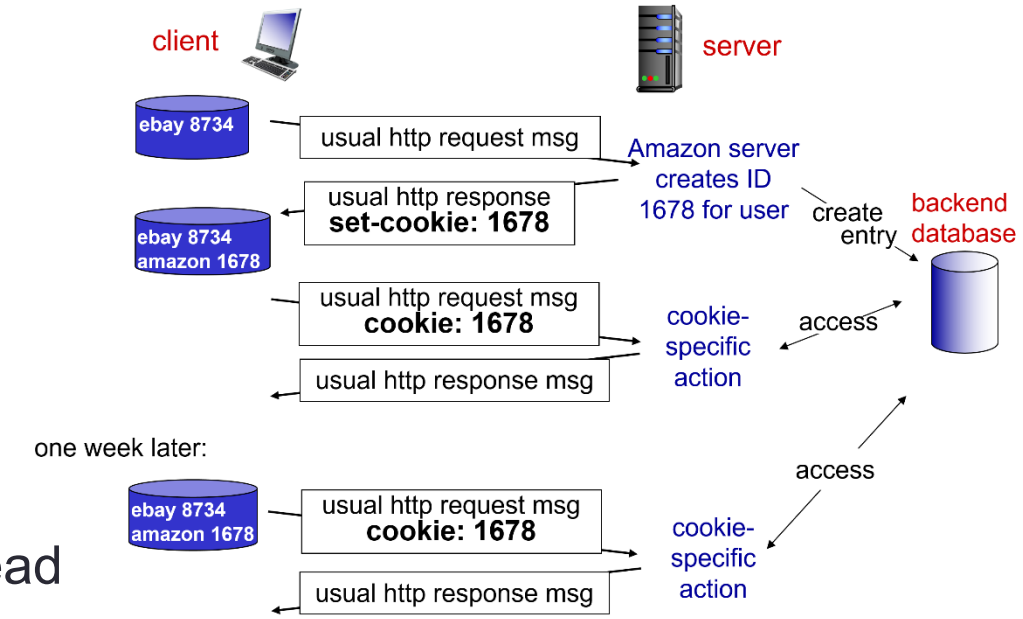
- Attack example*:*
  - *Accept-Language* – Because some web applications pass contents of field directly to database, attacker can inject SQL command by modifying header





Cookies

- HTTP does not have a mechanism for a website to track whether a user has previously visited that site
- **Cookies** – a web server stores user-specific information on user's local computer
- Web sites use cookies to identify repeat visitors
- Examples of information:
  - Travel Web sites may store user's travel itinerary
  - Personal information provided when visiting a site
- Only Web site that created a cookie can read it

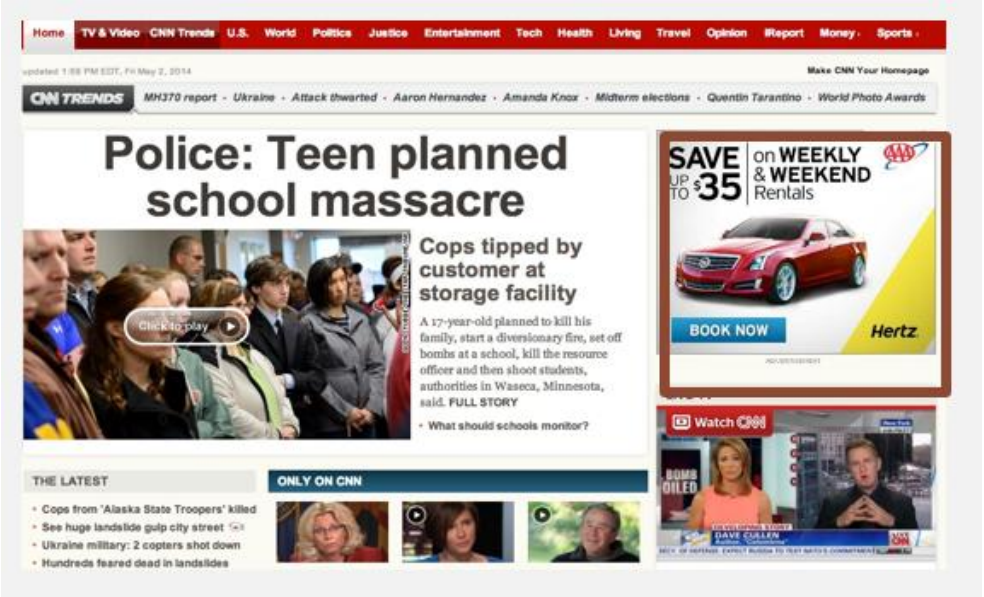


Cookies

- Executing basic attacks on First Party Cookies
  - Browser history fishing
  - Cookie theft and data extraction
- Cookies can contain personally identifiable information
- Although cookies often simplify the Internet shopping experience for the user, they are controversial because they can also be considered as an invasion of privacy

Types of Cookies

- **First-party cookie**
  - Cookie created by the Web site the user is currently visiting; e.g., www.cnn.com
    - Items in your shopping cart, login name
- **Third-party cookie**
  - Some websites attempt to place additional cookies on local hard drive
  - Often come from third parties that advertise on the site and want to record the user's preferences



Types of Cookies

- **Session cookie**
  - Stored in RAM and expires when browser is closed
- **Persistent cookie**
  - Recorded on computer’s hard drive and does not expire when browser closes

Locally Shared Object (LSO)

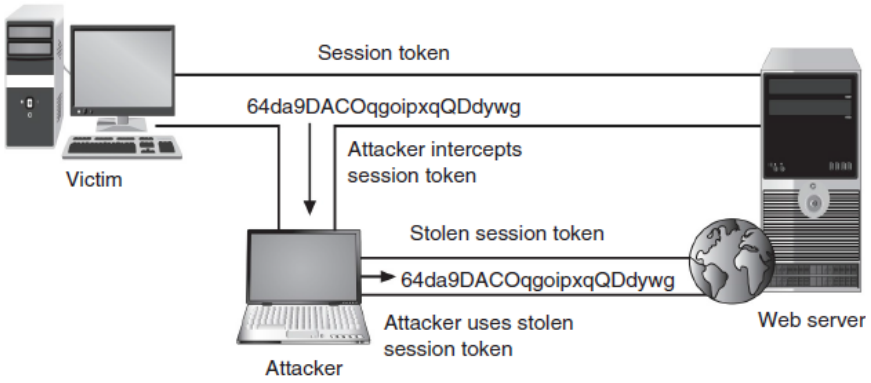
- **Locally shared object (LSO)** or **Flash cookie** - named after the Adobe Flash player
- Different from regular cookies:
  - Store more complex data
  - Store up to 100 KB of data (25 times more than regular cookie)
  - Cannot be deleted through browser's normal configuration settings
  - Saved in multiple locations on hard drive
  - Can be used to reinstate regular cookies that user deleted or blocked
  - In mid-2011, Adobe, after much criticism, released an online tool to delete LSOs

Risks of Cookies

- Security and privacy risks
- First-party cookies can be stolen and used to impersonate the user
- Third-party cookies can be used to track the browsing or buying habits of a user

Session Hijacking

- It is important that a user who is accessing a secure web application (e.g., online bookstore), can be verified
  - Prevent an imposter from “jumping in” to the interaction
- This verification is accomplished through a session token
  - a random string assigned to that interaction between the user and the web application currently being accessed
- Session hijacking is an attack in which an attacker attempts to impersonate the user by using her token



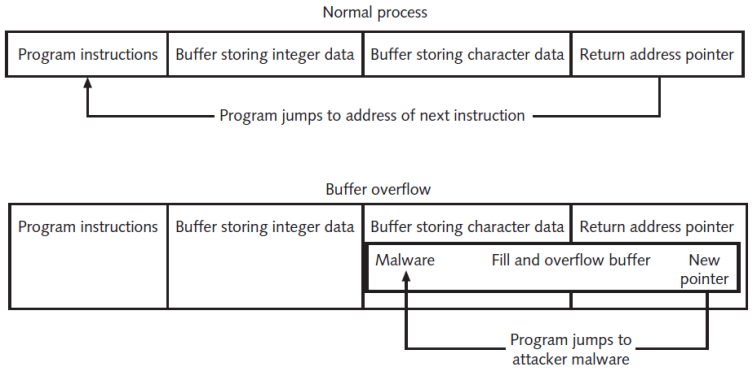
Impartial Overflow Attacks

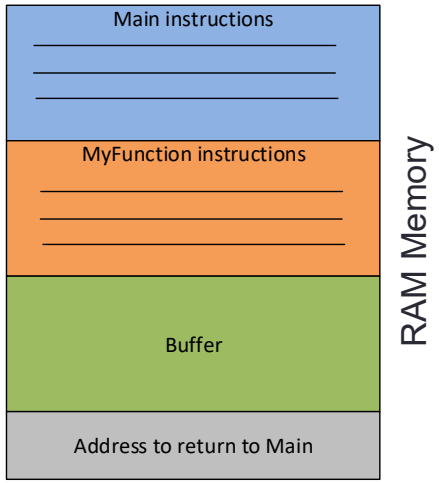
- “Impartial” attacks can target either server or client
- Many these attacks are designed to “overflow” areas of memory with instructions from the attacker
  - Buffer overflow attacks
  - Arbitrary/remote code execution attacks

Buffer Overflow Attack

- A process attempts to store data in RAM beyond the boundaries of a fixed-length storage buffer
- Extra data overflows into the adjacent memory locations
- The storage buffer typically contains the “return address” memory location
- Attacker can overflow the buffer with a new address pointing to the attacker’s malware code

```c
#include <stdio.h>


// THIS IS THE FUNCTION BEING CALLED FROM THE MAIN
int myFunction(char buffer[1000])
{

    // READ FROM NETWORK AND STORE IN BUFFER
    readFromNetwork(buffer);
    return 0;

}


// THIS IS THE MAIN FUNCTION - ENTRY POINT
int main(int argc, char *argv[])
{
    char buffer[1000];
    printf("Hello, world\n");
    myFunction(buffer);

    // HERE WE CAN PROCESS THE DATA IN BUFFER
    return 0;
}
```





Arbitrary/Remote Code Execution

- Allows attacker to run programs and execute commands on different computer
- Once under the attacker's control, computer can perform virtually any command from the attacker
- Arbitrary/remote code execution attacks often take advantage of malicious attachments like Microsoft Visio file or PDF file

Network Attacks

- Attackers place high priority on targeting networks
- Exploiting single vulnerability may expose hundreds or thousands of devices to an attacker
- Types of attacks that target a network or network process:
  - Denial of service
  - Interception
  - Poisoning
  - Attacks on access rights

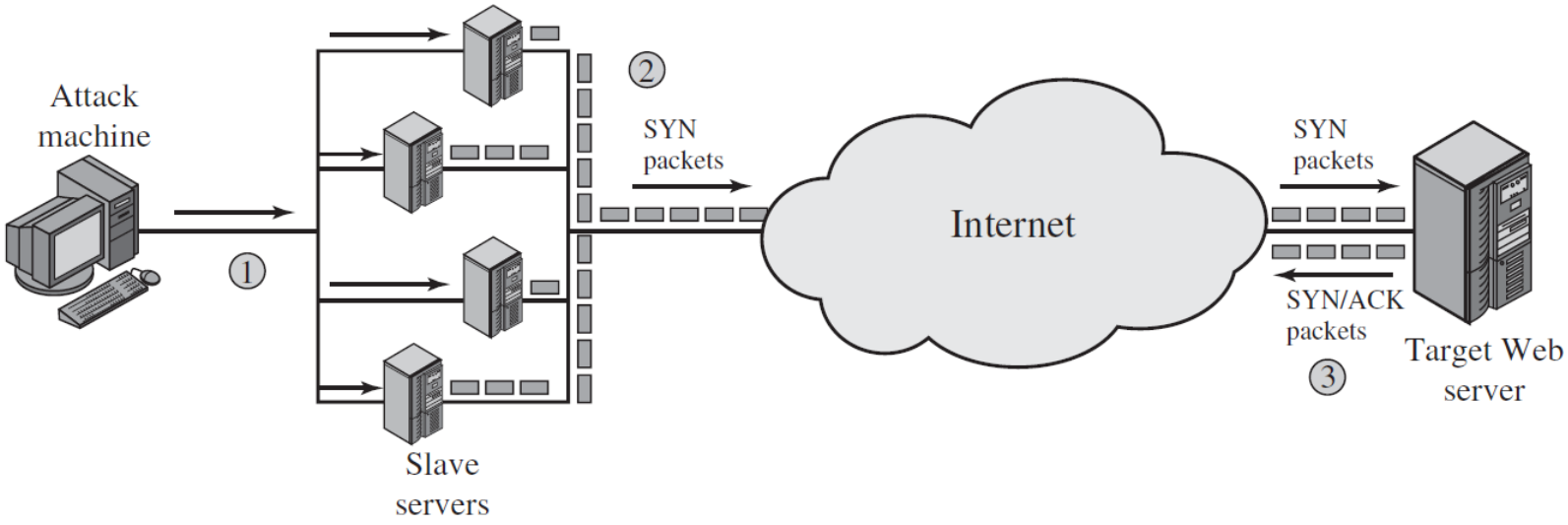
Denial of Service (DoS)

- Denial of service (DoS)

  Deliberate attempt to prevent authorized users from accessing a system

- Distributed denial of service (DDoS)

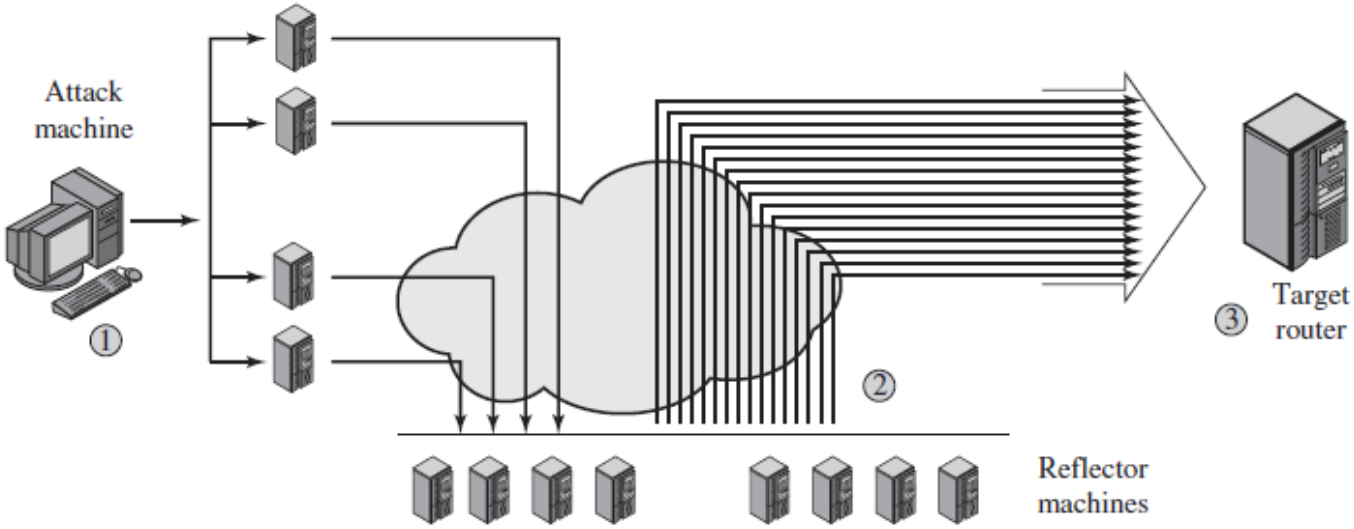
  Uses thousands zombie computers in botnet



Denial of Service (DoS)

- Ping flood attack

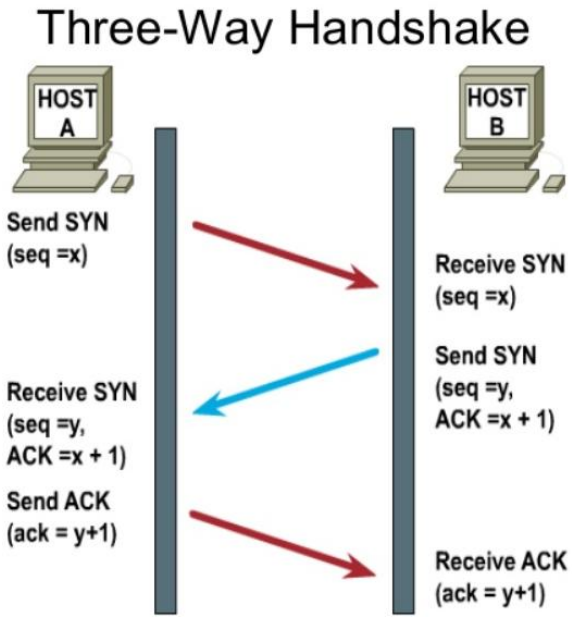
  Ping utility used to send large number of echo request messages and overwhelms server



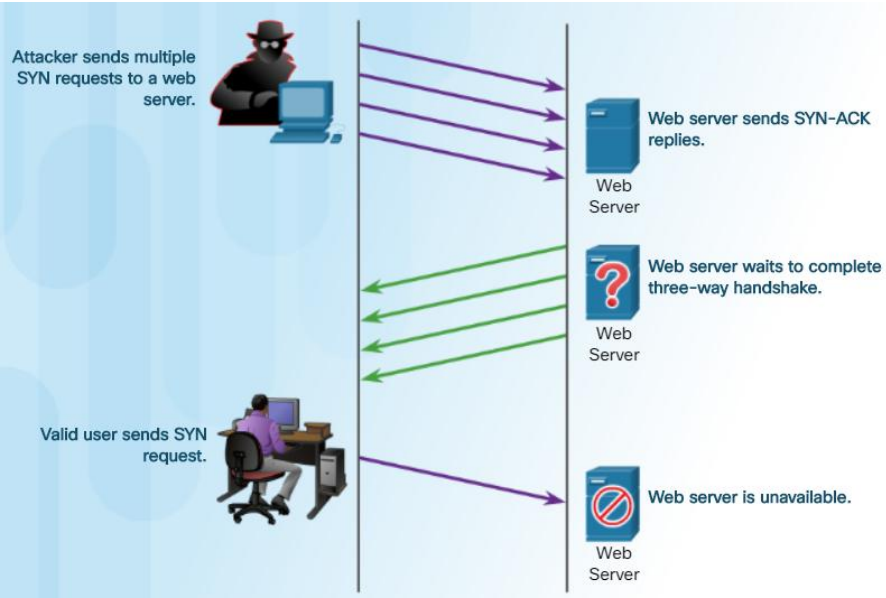
1. Attacker takes control of multiple hosts over the Internet, instructing them to send ICMP ECHO packets with the target's spoofed IP address to a group of hosts
2. Nodes at the bounce site receive multiple spoofed requests and respond by sending echo reply packets to the target site.
3. The target's router is flooded with packets from the bounce site

SYN Flood Attack

- Takes advantage of procedures for TCP connection



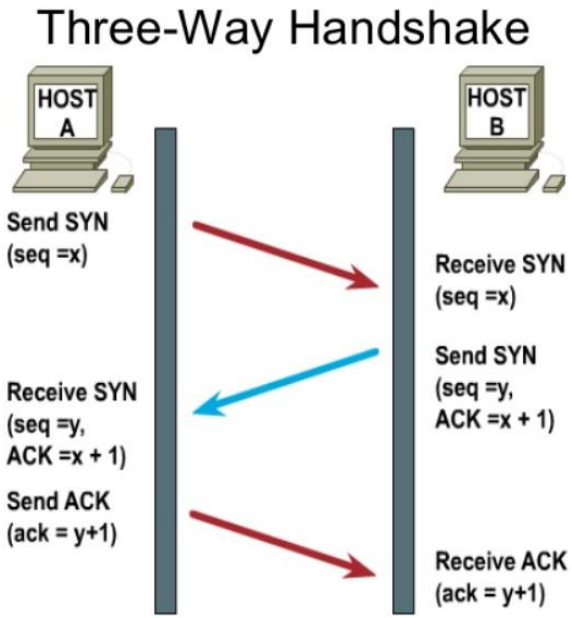
Regular TCP connection



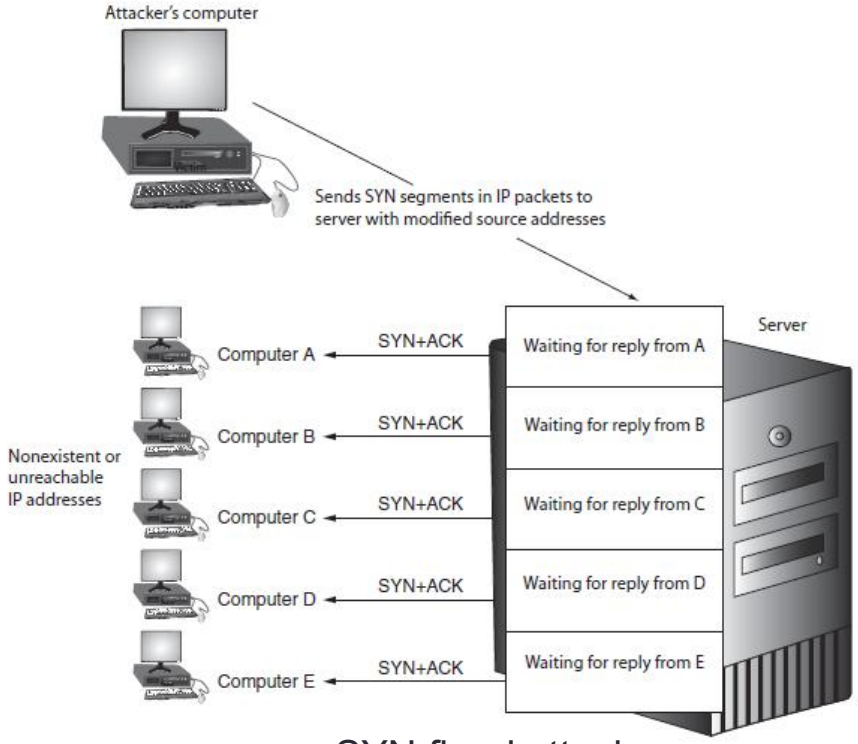
SYN flood attack

SYN Flood Attack

- Takes advantage of procedures for TCP connection



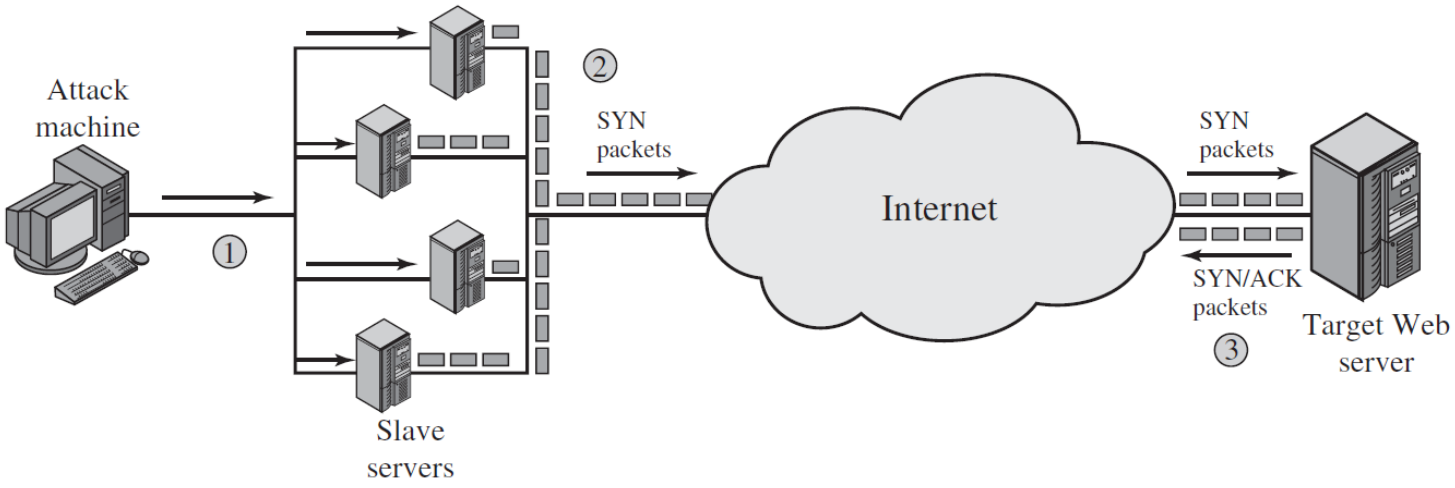
Regular TCP connection



SYN flood attack

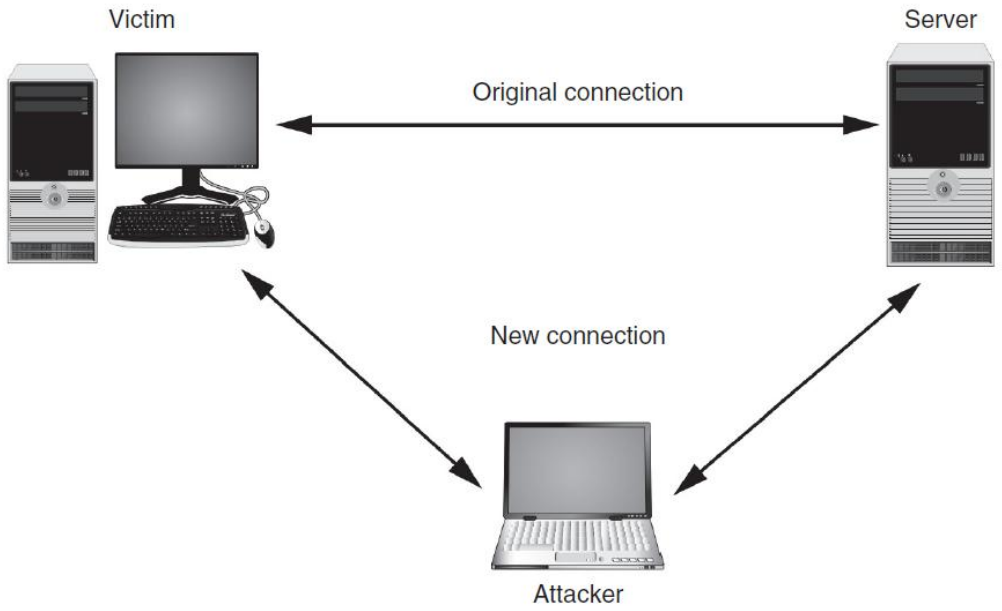
SYN Flood Attack

- Takes advantage of procedures for TCP connection



Interception Attacks

- Man-in-the-middle
  - Interception of legitimate communication
  - Passive attack records transmitted data
  - Active attack alters contents of transmission before sending to recipient



Interception Attacks

- Replay
  - Similar to passive man-in-the-middle attack
  - Replay makes a copy of the transmission before sending it to the recipient for use at a later time (the man-in-the-middle replays it)
- A simple replay would involve the man-in-the-middle capturing logon credentials between user and server
- Once that session has ended, the man-in-the-middle would attempt to log on and replay the captured credentials

Poisoning Attacks

- Poisoning introduces a substance that harms or destroys a functional device
- Two types of attacks inject “poison” into a normal network
  - ARP poisoning
  - DNS poisoning

ARP Poisoning

- TCP/IP requires that logical IP addresses be assigned to each host on a network
- However, an Ethernet LAN uses MAC address to send frames
- The sender must find the MAC address corresponding to the destination IP address
- The sender host uses the Address Resolution Protocol (ARP)

ARP Poisoning

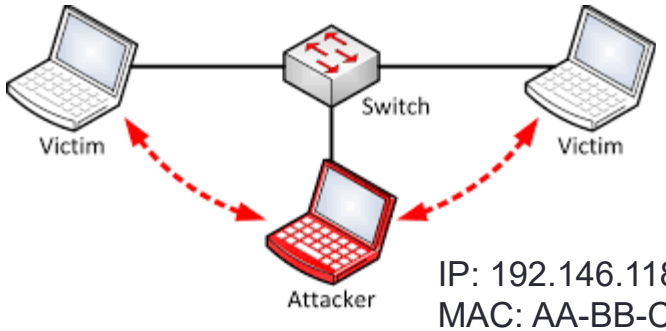
- If the IP address for a device is known but the MAC address is not, the sending computer sends an ARP packet to all computers… “If this is your IP address?”
- The computer with that IP address sends back a packet with the MAC address
- The corresponding MAC address is stored in an ARP cache for future reference

Poisoning Attacks

- ARP poisoning
  - Attacker modifies MAC address in ARP cache to point to different computer

Device	IP and MAC address	ARP cache before attack	ARP cache after attack
Attacker	192.146.118.2 & 00-AA-BB-CC-DD-02	192.146.118.3=>00-AA-BB-CC-DD-03 192.146.118.4=>00-AA-BB-CC-DD-04	192.146.118.3=>00-AA-BB-CC-DD-03 192.146.118.4=>00-AA-BB-CC-DD-04
Victim 1	192.146.118.3& 00-AA-BB-CC-DD-03	192.146.118.2=>00-AA-BB-CC-DD-02 192.146.118.4=>00-AA-BB-CC-DD-04	192.146.118.2=>00-AA-BB-CC-DD-02 192.146.118.4=>00-AA-BB-CC-DD-02
Victim 2	192.146.118.4 & 00-AA-BB-CC-DD-04	192.146.118.2=>00-AA-BB-CC-DD-02 192.146.118.3=>00-AA-BB-CC-DD-03	192.146.118.2=>00-AA-BB-CC-DD-02 192.146.118.3=>00-AA-BB-CC-DD-02

IP: 192.146.118.3
MAC: AA-BB-CC-DD-03



IP: 192.146.118.4
MAC: AA-BB-CC-DD-04

IP: 192.146.118.2
MAC: AA-BB-CC-DD-02

DNS Poisoning

- Domain Name System is the current basis for name resolution to IP address
- **DNS poisoning** substitutes DNS addresses to redirect computer to another device
- DNS poisoning
- Two locations for DNS poisoning:
  - Local host table
  - External DNS server

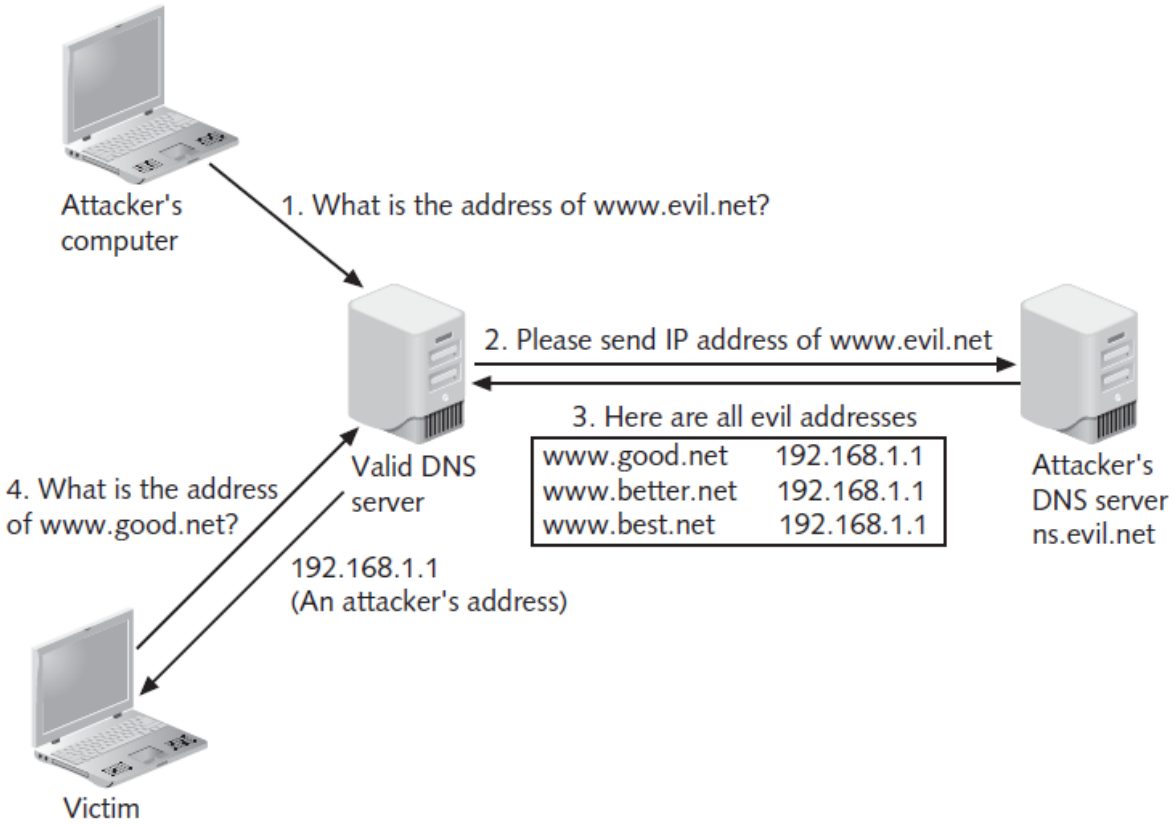
Sample HOSTS file

- When a user enters a symbolic name (www.cnn.com), TCP/IP first checks the local host table to determine if there is an entry
- If no entry exists, then the external DNS system is used
- Attackers can target a local hosts file to create new entries that will redirect users to their fraudulent site

```
# Copyright (c) 1993–1999 Microsoft Corp.
#
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
#
# This file contains the mappings of IP addressed to host names. Each
#  entry should be kept on an individual line. The IP address should
#  be placed in the first column followed by the corresponding host name.
#  The IP address and the host name should be separated by at least one
#  space.
#
#  Additionally, comments (such as these) may be inserted on individual
#  lines or following the machine name denoted by a '#' symbol.
#
#  for example:
#
#       102.54.94.97        rhino.acme.com      # source server
#       38.25.63.10         x.acme.com          # x client host
#
#

127.0.0.1          localhost
161.6.18.20        www.wku.edu          # Western Kentucky University
74.125.47.99       www.google.com       # My search engine
216.77.188.41      www.att.net          # Internet service provider
204.15.20.80       www.facebook.com
```

Sample HOSTS file

- E.g., www.google.com -> 216.58.197.142
- C:\Windows\System32\drivers\etc

```
# Copyright (c) 1993–1999 Microsoft Corp.
#
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
#
# This file contains the mappings of IP addressed to host names. Each
#  entry should be kept on an individual line. The IP address should
#  be placed in the first column followed by the corresponding host name.
#  The IP address and the host name should be separated by at least one
#  space.
#
#  Additionally, comments (such as these) may be inserted on individual
#  lines or following the machine name denoted by a '#' symbol.
#
#  for example:
#
#       102.54.94.97        rhino.acme.com        # source server
#       38.25.63.10         x.acme.com            # x client host
#
#

127.0.0.1          localhost
161.6.18.20        www.wku.edu            # Western Kentucky University
74.125.47.99       www.google.com         # My search engine
216.77.188.41      www.att.net            # Internet service provider
204.15.20.80       www.facebook.com
```

DNS Poisoning